

Architecture: Identity and Access Management

Meridian Commercial Bank - Internal Document

doc_id:	ARCH-IAM-004
document_type:	architecture
department:	security
access_level:	internal
created_date:	2025-02-10

Overview

Describes the Identity and Access Management (IAM) architecture used across Meridian Commercial Bank's internal and customer-facing systems, including the role model used by the internal AI Assistant.

Components

- Identity Provider (IdP): Issues signed tokens (short-lived access tokens plus refresh tokens) for both customer-facing apps and internal tools. Token signing keys rotate on a scheduled basis via automated certificate renewal (see INC-2026-07-08-006 for a case where this automation failed).
- Role Service: Maintains role assignments for internal users. For the internal AI Assistant POC, three roles are defined: Viewer, Analyst, and Administrator.
- Policy Enforcement Point (PEP): A shared authorization library used by internal services (including the AI Assistant backend) to check whether a given role may perform a given action before executing it.

Role Definitions (Internal AI Assistant)

- Viewer: May use chat and knowledge search. May not invoke administrative or analytical tools.
- Analyst: May use search, analytics tools (Python Analysis Tool), and MCP tools (employee directory, service catalog, incident records).
- Administrator: May use all tools, including reindexing the knowledge base and viewing system-wide usage/feedback data.

Enforcement Principle

Authorization checks must be enforced at the point of tool execution on the backend, never solely in the UI or solely via prompt instructions to the LLM. This ensures that neither a modified client request nor a crafted prompt-injection attempt can cause the agent to bypass role restrictions enforced by the PEP.

Related Documents

- ARCH-data-platform (Document Index access filtering uses the same role model)
- RB-card-fraud-alert-triage (Fraud Operations step-up verification uses the IdP's step-up authentication flow)